

CYBER THREAT INTELLIGENCE

CTI, OSINT, MISP Architecture,
& Adversary Profiling.

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

HAK CIPTA & DISCLAIMER

Cyber Threat Intelligence (CTI) & Open-Source Intelligence (OSINT)
Edisi Enterprise (50 Halaman)

Disusun oleh: Rizki Angga Pratama, S. Kom, C. Pro

Dokumen ini dirancang khusus bagi Security Analysts dan Threat Hunters yang ingin bertransformasi dari sekadar merespons insiden (Reaktif) menjadi memetakan, mengumpulkan, dan mengantisipasi operasi musuh (Proaktif).

> **Catatan Intelijen (OPSEC):**
> Aktivitas OSINT dan perburuan CTI melibatkan interaksi langsung atau tidak langsung dengan infrastruktur musuh (*Threat Actors*). Pastikan setiap pencarian dan pengumpulan data dilakukan melalui lingkungan terisolasi (*Sandbox*), VPN ganda, atau mesin Tor/Tails. Jangan pernah melakukan *Active Reconnaissance* menggunakan alamat IP perusahaan Anda.

Filosofi Desain:
Disajikan dengan visual *Tactical Grey & Radar Green*, melambangkan operasi bayangan (*Covert Ops*), analisis graf node intelijen, dan radar deteksi di garis depan operasi militer siber.

© 2026 Hak cipta dilindungi undang-undang. Dokumen Pelatihan Analis CTI.

KATA PENGANTAR

Di dalam *Security Operations Center (SOC)*, Anda akan dengan cepat menyadari sebuah fakta yang suram: Jika Anda hanya mengandalkan log dari *Firewall* dan Antivirus Anda sendiri, Anda selalu selangkah di belakang musuh. Anda baru bertindak setelah kerusakan terjadi.

Keamanan siber bukanlah pertandingan yang adil. Penyerang (*Advanced Persistent Threats / APTs*) berbagi taktik, menjual alat, dan mendistribusikan daftar kerentanan di forum-forum gelap. Jika tim pertahanan tidak membangun jaringan intelijen yang sama kuatnya, kekalahan hanyalah masalah waktu.

Cyber Threat Intelligence (CTI) adalah seni mengubah informasi yang berserakan menjadi pengetahuan operasional yang mematikan bagi musuh. CTI memberi tahu Anda *siapa* yang mungkin menyerang perusahaan Anda bulan depan, *alat apa* yang akan mereka gunakan, dan *kerentanan mana* yang sedang mereka targetkan.

Dalam e-book ini, kita akan membongkar *The Pyramid of Pain*, membedah struktur *Diamond Model*, dan mempraktikkan OSINT tingkat mahir menggunakan Shodan dan Maltego. Lebih dari sekadar teori, kita akan mendirikan peladen **MISP** (*Malware Information Sharing Platform*) untuk secara otomatis menarik jutaan Indikator Kompromi (IoC) dan memasukkannya langsung ke dalam aturan *blocking* mesin SIEM Anda.

Pengetahuan adalah senjata. Mari bersenjata.

— Rizki Angga Pratama

Author

DAFTAR ISI (1/2)

BAGIAN I: Fondasi Cyber Threat Intelligence

Bab 1.1 Intelijen vs Data Mentah (Konsep Dasar) Hlm. 7

Bab 1.2 Tiga Tingkatan CTI (Strategis, Operasional, Taktis) Hlm. 8

Bab 1.3 Siklus Intelijen (The Intelligence Cycle) Hlm. 9

Bab 1.4 IoC (Indicators of Compromise) vs IoA Hlm. 10

Bab 1.5 Anatomi The Pyramid of Pain Hlm. 11

Bab 1.6 TTPs (Tactics, Techniques, & Procedures) Hlm. 12

BAGIAN II: Open-Source Intelligence (OSINT)

Bab 2.1 Passive vs Active Reconnaissance Hlm. 14

Bab 2.2 Shodan: Mesin Pencari Infrastruktur Gelap Hlm. 15

Bab 2.3 Enumerasi DNS (DNSDumpster & theHarvester) Hlm. 16

Bab 2.4 Google Dorks untuk Penemuan Dokumen Rahasia Hlm. 17

Bab 2.5 Maltego: Analisis Graf Hubungan Entitas Hlm. 18

Bab 2.6 SOCMINT (Social Media Intelligence) & Phishing Prep Hlm. 19

Bab 2.7 Analisis Metadata Fail (ExifTool dalam OSINT) Hlm. 20

Bab 2.8 Operasi OPSEC (Keamanan Peneliti CTI) Hlm. 21

DAFTAR ISI (2/2)

BAGIAN III: Model Analitik & Profiling Musuh

Bab 3.1 The Diamond Model of Intrusion Analysis Hlm. 23

Bab 3.2 MITRE ATT&CK Framework dalam Konteks CTI Hlm. 24

Bab 3.3 Lockheed Martin Cyber Kill Chain Hlm. 25

Bab 3.4 Profiling APT (Contoh: Lazarus Group) Hlm. 26

Bab 3.5 Atribusi (Attribution): Menentukan Siapa Pelakunya Hlm. 27

Bab 3.6 Membaca & Mengekstrak Laporan Vendor CTI Hlm. 28

BAGIAN IV: Threat Intelligence Platforms (TIP)

Bab 4.1 Apa itu TIP? (Threat Intelligence Platform) Hlm. 30

Bab 4.2 Arsitektur MISP (Malware Info Sharing Platform) Hlm. 31

Bab 4.3 Taksonomi MISP (Events, Attributes, Galaxies) Hlm. 32

Bab 4.4 Standar Pertukaran Intelijen: STIX & TAXII Hlm. 33

Bab 4.5 OpenCTI: Pendekatan Berbasis Knowledge Graph Hlm. 34

Bab 4.6 Mengelola TLP (Traffic Light Protocol) Hlm. 35

BAGIAN V: Operasionalisasi CTI di SOC

Bab 5.1 Ingesti Threat Feeds ke SIEM (Elastic/Splunk) Hlm. 37

Bab 5.2 KQL: Mencocokkan Log Jaringan dengan CTI Hlm. 38

Bab 5.3 Hypothesis-Driven Threat Hunting Hlm. 39

Bab 5.4 Penulisan Aturan YARA dari Laporan CTI Hlm. 40

Bab 5.5 Integrasi CTI dengan SOAR (Auto-Blocking) Hlm. 41

Glosarium CTI & OSINT (A-M) Hlm. 48

Glosarium CTI & OSINT (N-Z) Hlm. 49

Back Cover (The Tactical Mind) Hlm. 50



BAGIAN I

Fondasi Cyber Threat Intelligence
& Siklus Intelijen

BAB 1: DASAR INTELIJEN ANCAMAN

1.1 Intelijen vs Data Mentah

Kesalahan terbesar analis SOC pemula adalah menganggap bahwa daftar panjang 10.000 alamat IP jahat (*Malicious IPs*) yang diunduh dari internet adalah **Intelijen**. Itu salah. Daftar IP tersebut hanyalah **Data Mentah (Raw Data)**.

Data mentah menjadi **Informasi** ketika diurutkan dan dikategorikan (Misal: 1.000 IP dari daftar tadi berasal dari Tiongkok). Informasi baru berubah menjadi **Intelijen (Intelligence)** ketika data tersebut diberikan *Konteks, Analisis, dan Relevansi Tindakan (Actionability)*.

> **Contoh Intelijen Sejati:**
> "Kelompok peretas APT29 (berbasis di Rusia) sedang aktif melakukan pemindaian massal terhadap kerentanan `CVE-2023-XXXX` pada perangkat *Pulse Secure VPN*. Karena perusahaan kita menggunakan VPN tersebut, kita adalah target yang relevan. Blokir segera rentang IP `185.x.x.x/24` dan perbarui perangkat VPN kita malam ini."

Intelijen menjawab pertanyaan: *Siapa? Mengapa? Bagaimana? Dan apa yang harus kita lakukan sekarang?*

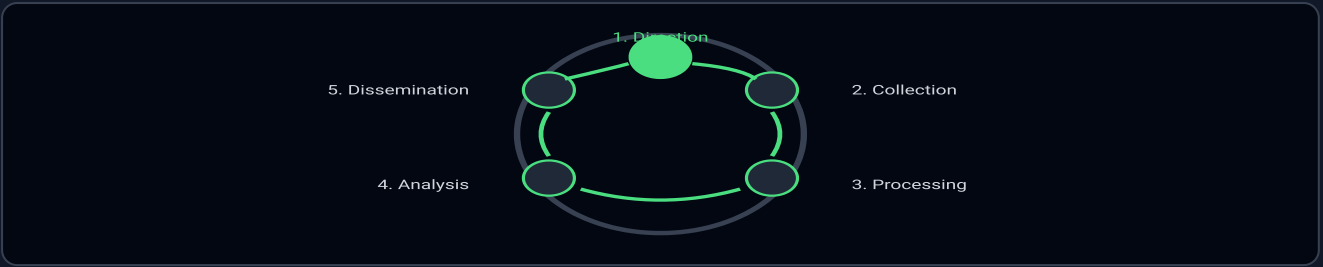
1.2 Tiga Tingkatan CTI

Intelijen ancaman tidak dibuat sama; ia disajikan dengan bahasa yang berbeda untuk pelanggan (*Consumers*) yang berbeda di dalam perusahaan.

- **Strategic CTI (Strategis):** Ditujukan untuk Dewan Direksi (C-Level/CISO). Fokus pada gambaran besar, tren kerentanan global, dan risiko bisnis. Formatnya berupa presentasi PDF, bukan deretan kode. (Misal: *"Serangan Ransomware di sektor perbankan naik 40%, kita perlu menambah anggaran tim SOC."*)
- **Operational CTI (Operasional):** Ditujukan untuk Manajer SOC dan *Threat Hunters*. Fokus pada Taktik, Teknik, dan Prosedur musuh (TTPs). Menggunakan kerangka kerja *MITRE ATT&CK*. (Misal: *"Geng LockBit menggunakan teknik DLL Hijacking. Perintahkan tim untuk berburu anomali DLL di EDR."*)
- **Tactical CTI (Taktis):** Ditujukan untuk Analis L1, SIEM, dan *Firewall*. Ini adalah CTI yang paling teknis, berisi mesin-baca (*machine-readable*) Indikator Kompromi (IoC) seperti Hash MD5, URL Phishing, dan Alamat IP (*Threat Feeds*). Di sinilah platform *MISP* beroperasi.

1.3 Siklus Intelijen (The Intelligence Cycle)

Tim CTI tidak bekerja secara acak. Mereka bekerja mengikuti doktrin militer klasik yang disebut **Siklus Intelijen**, yang terdiri dari 5 fase berulang:



1. **Direction (Perencanaan):** Menentukan apa yang ingin kita cari. (PIR - *Priority Intelligence Requirements*).
2. **Collection (Pengumpulan):** Melakukan OSINT, menarik log SIEM, menyusup ke *Dark Web*.
3. **Processing:** Membersihkan data (menghapus IP palsu, menstandarkan format JSON/STIX).
4. **Analysis (Analisis):** Mengubah data bersih menjadi cerita (*Profiling musuh*).
5. **Dissemination (Penyebaran):** Menyerahkan laporan PDF ke CISO, dan mendorong blok *Hash* ke EDR.

1.4 IoC vs IoA (Indicators of Attack)

Dalam intelijen, kita membedakan dua jenis artefak forensik:

Indicators of Compromise (IoC):
Ini adalah barang bukti (DNA) yang tertinggal *setelah* peretasan terjadi. IoC bersifat statis. Contohnya: Hash *Malware* `e3b0c442...`, Alamat IP C2 `185.10.x.x`, atau kunci *Registry* spesifik. Jika IoC ini ditemukan di jaringan Anda, artinya **Anda sudah diretas**.

Indicators of Attack (IoA):
Ini adalah fokus dari *Threat Hunting* modern. IoA tidak peduli dengan alamat IP musuh; IoA berfokus pada **Niat dan Perilaku (Behavior)**. Contoh: *"Sebuah proses `powershell.exe` menelurkan koneksi jaringan ke port 443 yang mengekstrak data 500MB dalam bentuk arsip RAR."*
Meskipun penyerang mengganti IP atau mengganti kode *Malware* (Hash berubah), perilaku mengarsipkan data dengan RAR (IoA) tidak bisa mereka tutupi. IoA bersifat proaktif.

1.5 Anatomi The Pyramid of Pain

Konsep paling fundamental dalam CTI diciptakan oleh David Bianco, yang disebut **The Pyramid of Pain (Piramida Rasa Sakit)**. Piramida ini mengukur *seberapa menderita (Painful)* sang penyerang jika Anda berhasil memblokir intelijen tersebut.



Jika Anda memblokir **Hash Value** (Dasar Piramida), penyerang hanya perlu mengubah 1 bit (*recompile*) *malware*-nya, Hash akan berubah, dan mereka bisa menyerang Anda lagi detik itu juga. Memblokir Hash membuat musuh *Trivial* (Sangat mudah) menghindarinya.

1.6 TTPs (Tertinggi di Piramida)

Lanjutan dari Piramida Rasa Sakit (Bab 1.5):

- **IP Addresses & Domains (Mudah):** Penyerang dapat menyewa VPS atau domain baru seharga 5 dolar dan mem-*bypass* *firewall* Anda dalam 5 menit.
- **Tools (Menantang):** Jika Anda berhasil membuat *Rule* YARA yang memblokir alat (*Tools*) *Cobalt Strike* secara keseluruhan, musuh akan sangat kesakitan. Mereka harus menyerah, atau membuang waktu berminggu-minggu membuat *malware* C2 tipe baru.
- **TTPs - Tactics, Techniques, Procedures (Puncak Piramida - Sangat Sulit):** Ini adalah perilaku psikologis dan prosedur operasional musuh. Jika Anda mendeteksi TTP mereka (misalnya taktik mereka selalu menggunakan *WMI Exec* untuk menyebar lateral), musuh harus **mempelajari ulang seluruh cara mereka bekerja**. Menggagalkan TTP berarti Anda telah mengalahkan grup APT tersebut secara struktural.

Fokus utama analis CTI tingkat L3 adalah menerjemahkan intelijen tingkat rendah (IP/Hash) ke dalam TTP menggunakan *MITRE ATT&CK*.



BAGIAN II

Open-Source Intelligence (OSINT)
& Active/Passive Reconnaissance

BAB 2: PRAKTIK OSINT

2.1 Passive vs Active Reconnaissance

Open-Source Intelligence (OSINT) adalah proses mengumpulkan, menganalisis, dan mengambil kesimpulan dari informasi yang tersedia secara publik (Internet, Media Sosial, Catatan Pemerintah) secara legal.

Dalam intelijen siber, operasi pengintaian (*Reconnaissance*) terbagi menjadi dua:

1. Active Reconnaissance (Mengguncang Pintu):
Anda mengirim paket langsung ke peladen target (misalnya melakukan *Port Scan* dengan Nmap atau memindai kerentanan dengan *Nikto/Nuclei*). Ini sangat bising, ilegal (jika tanpa izin), dan akan langsung tercatat di log *Firewall/SIEM* target. Tim CTI **TIDAK** menggunakan metode ini.

2. Passive Reconnaissance (Menonton dari Jauh):
Anda tidak pernah menyentuh peladen target sekalipun. Anda mencari informasi tentang target melalui layanan pihak ketiga yang telah memindai internet untuk Anda (seperti Google, Shodan, atau *Archive.org*). Target tidak memiliki catatan (Log) bahwa Anda sedang menyelidiki mereka. Inilah inti dari OSINT yang sesungguhnya.

2.2 Shodan: Mesin Pencari Infrastruktur Gelap

Jika Google adalah mesin pencari untuk situs web (HTML), maka **Shodan (shodan.io)** dan **Censys** adalah mesin pencari untuk *Internet of Things (IoT)*, *Server*, dan perangkat jaringan. Shodan secara pasif memindai seluruh alamat IP publik di dunia dan menyimpan *Banner Grab* (informasi port/servis terbuka).

Seorang analis CTI menggunakan Shodan untuk mencari infrastruktur musuh (Peladen C2) atau mengevaluasi kerentanan perimeter perusahaan sendiri (*External Attack Surface Management*).

```
# Contoh Pencarian (Dorking) di Shodan # Mencari peladen RDP (Port 3389) yang terekspos milik organisasi target org:"PT Target Corp" port:"3389" # Memburu peladen C2 Cobalt Strike secara global (berdasarkan sertifikat SSL default) ssl.cert.subject.cn:"cobaltstrike" port:443 # Mencari IP peladen Database Elasticsearch terbuka (tanpa password) di Indonesia product:"Elasticsearch" country:"ID" "200 OK"
```

2.3 Enumerasi DNS (DNSDumpster & theHarvester)

Untuk memetakan wilayah target (*Attack Surface*), analis membutuhkan daftar *Subdomain* dan Email target. Penyerang sering menyembunyikan portal *VPN/Dev* rahasia di subdomain yang tidak tertaut ke situs utama (misal: `vpn-beta.perusahaan.com`).

Alat seperti **DNSDumpster.com** memungkinkan analis memetakan grafik relasi antara *DNS Records (A, MX, TXT)* organisasi, mengungkap peladen *Email* dan rentang IP *Hosting* secara pasif.

Dalam otomatisasi CLI, alat legendaris **theHarvester** akan menarik informasi dari LinkedIn, Baidu, Bing, dan Google untuk menyusun ribuan alamat email karyawan yang sah beserta daftar *subdomain*, cukup dengan satu baris perintah:

```
python3 theHarvester.py -d perusahaan.com -l 500 -b google,linkedin,crtsh
```

Data email ini digunakan oleh *Red Team* untuk menyusun kampanye *Spear Phishing*, dan digunakan oleh *Blue Team* (CTI) untuk melindungi nama-nama VIP yang terekspos.

2.4 Google Dorks (Advanced Search Operators)

Banyak rahasia perusahaan (kata sandi, fail *database*, dokumen Excel rahasia) secara tidak sengaja terindeks oleh bot Google (*Googlebot*). Untuk menemukannya, analis CTI menggunakan taktik **Google Hacking / Google Dorking**.

Dengan menggabungkan operator pencarian logis yang kompleks, Google bertransformasi dari mesin pencari artikel menjadi mesin pencari kerentanan tingkat tinggi.

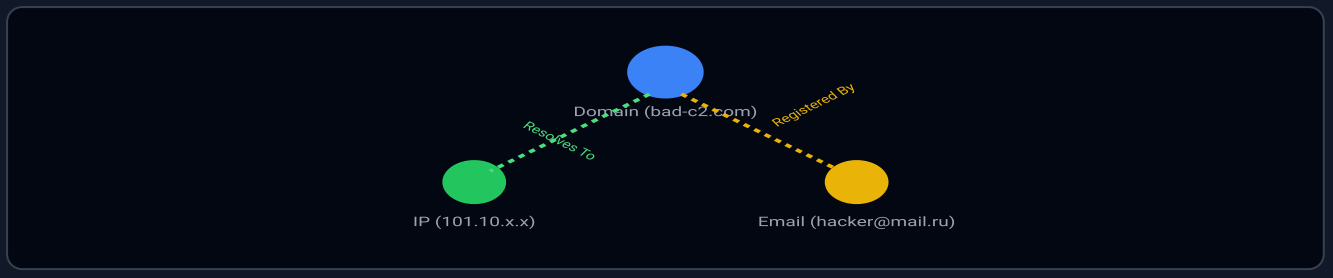
```
# OSINT: Kumpulan Google Dorks Kritis # Mencari file Excel (.xlsx) di situs target yang mengandung kata "password" site:target.com ext:xlsx intext:"password" OR intext:"credentials" # Menemukan folder Direktori terbuka (Open Directory / Index of) intitle:"index of" "backup" site:target.com # Mencari kunci Private SSH/RSA yang terekspos ke internet intitle:"index of" "id_rsa" -site:github.com
```

Repositori resmi (*Google Hacking Database / GHDB*) di situs *Exploit-DB* menyimpan ribuan *dorks* siap pakai untuk mengidentifikasi panel *Login* admin yang tersembunyi atau berkas konfigurasi peladen yang tertinggal (misal `.env` atau `wp-config.php`).

2.5 Maltego: Analisis Graf Hubungan Entitas

Setelah mengumpulkan ribuan alamat IP, Email, Domain, dan nomor telepon, analis menghadapi masalah: **Data Overload (Kelebihan Data)**. Sulit bagi otak manusia untuk melihat relasi tersembunyi di dalam *spreadsheet* Excel.

Maltego adalah perangkat lunak *Link Analysis* (Analisis Tautan) terstandar industri intelijen. Ia mengubah data teks mentah menjadi grafik nodal (*Node Graph*).



Di Maltego, Anda melakukan eksekusi **Transforms**. Anda klik kanan pada *Node Domain* jahat, lalu pilih *Transform* "To Email (WHOIS)". Maltego akan secara otomatis memanggil API pihak ketiga di latar belakang, menarik email pendaftar domain tersebut, dan menggambarkannya sebagai *Node* baru yang terhubung. Ini memungkinkan analis membongkar sindikat musuh dalam hitungan menit.

2.6 SOCMINT & Phishing Prep

Cabang spesifik dari OSINT yang menargetkan manusia adalah **Social Media Intelligence (SOCMINT)**. Jaringan pertahanan teknis terbaik di dunia (*Firewall* miliaran rupiah) dapat dihancurkan dalam satu kali klik (*Click*) oleh satu orang karyawan yang terkena *Spear Phishing* (Email penipuan yang sangat personal).

APT (Musuh level negara) menghabiskan waktu berminggu-minggu mempelajari *LinkedIn*, *Twitter/X*, dan *Instagram* target (Karyawan Level Tinggi atau Admin TI).

Jika intelijen musuh mengetahui dari *LinkedIn* bahwa Manajer Keuangan Anda, *Bapak Budi*, baru saja mengikuti konferensi Pajak Tahunan di Bali, musuh akan merancang email bertema: *"Budi, Berikut adalah Salinan Revisi Regulasi Pajak dari Konferensi Bali (PDF.exe)"*.

Sebagai analis intelijen internal (CTI), tugas Anda adalah melakukan *Self-SOCMINT* (Mengintai perusahaan sendiri). Temukan informasi apa yang berlebihan yang diekspos oleh karyawan Anda, dan peringatkan mereka sebelum peretas merangkainya menjadi senjata *Social Engineering*.

2.7 Analisis Metadata Fail (ExifTool)

Setiap dokumen (PDF, Word) dan gambar (JPEG) yang dipublikasikan oleh perusahaan ke internet (melalui *website* resmi) membawa penumpang gelap yang disebut **Metadata (EXIF Data)**. Ini adalah data tersembunyi mengenai fail tersebut.

Metadata dapat membocorkan *Username* penulis (*Author*), tipe sistem operasi yang digunakan, versi *Microsoft Office* yang digunakan (berguna untuk merancang eksploitasi makro yang spesifik), bahkan koordinat GPS tempat foto diambil.

```
# Eksekusi Terminal (OSINT): Mengekstrak Metadata dari Dokumen Publik $ exiftool
company_annual_report.pdf ExifTool Version Number : 12.40 File Name : company_annual_report.pdf File
Type : PDF Author : john.doe_admin Creator Tool : Microsoft Word for Office 365 OS Version : Windows
10.0.19042 # [!] Kritis: Peretas sekarang tahu ada user bernama "john.doe_admin" # dan dia menggunakan
Windows 10 versi rentan.
```

Tim keamanan harus menerapkan kebijakan *Metadata Scrubbing* di proksi web (*Web Gateway*) untuk menghapus (mensterilkan) data EXIF sebelum fail diunduh ke internet publik.



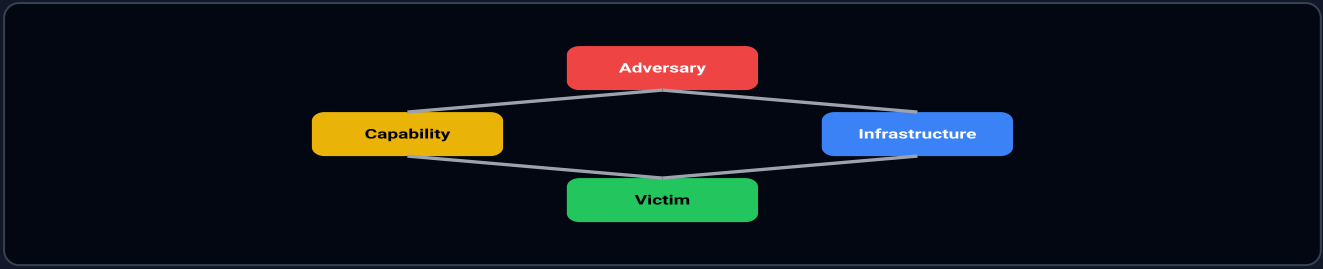
BAGIAN III

Model Analitik &
Profiling Musuh (Adversary)

BAB 3: PROFILING APT

3.1 The Diamond Model

Jika piramida mengukur apa yang digunakan musuh (Artefak), **Diamond Model of Intrusion Analysis** membedah struktur dari *sebuah peristiwa (Event) serangan siber*. Setiap peretasan yang terjadi di dunia ini pasti melibatkan empat titik mutlak yang saling terhubung membentuk berlian:



1. **Adversary (Musuh):** Siapa di balik *keyboard*? (Contoh: Geng APT29).
2. **Victim (Korban):** Siapa targetnya? (Contoh: Sektor Perbankan di Asia).
3. **Capability (Kemampuan):** Alat/Senjata apa yang dipakai? (Contoh: *Cobalt Strike* / *Custom Ransomware*).
4. **Infrastructure (Infrastruktur):** Di mana mereka menyimpan senjatanya? (Contoh: Peladen C2 di Rusia, IP `145.x.x.x`).

Jika analis CTI hanya tahu Korban (Perusahaan) dan Infrastrukturnya (IP), analis menggunakan *Diamond Model* (Korelasi Pivot) untuk menebak siapa Musuhnya dan Senjata apa yang kemungkinan besar akan menanti di dalam IP tersebut.

3.2 MITRE ATT&CK Framework dalam CTI

Kerangka Kerja **MITRE ATT&CK** (*Adversarial Tactics, Techniques, and Common Knowledge*) adalah kamus global (Rosetta Stone) bagi operasi keamanan siber. Ia menstandarisasi bagaimana cara kita membicarakan serangan.

Matriks ini terbagi menjadi:

- **Tactics (Taktik - Tujuan):** *Mengapa musuh melakukan sesuatu?* (Contoh: TA0008 - *Lateral Movement* / Ingin berpindah ke mesin lain).
- **Techniques (Teknik - Cara):** *Bagaimana mereka mencapai tujuan tersebut?* (Contoh: T1550 - *Use Alternate Authentication Material* / Menggunakan Kredensial Alternatif).
- **Procedures (Prosedur - Detail):** *Implementasi spesifik dari teknik tersebut.* (Contoh: Musuh A menggunakan Mimikatz versi 2.1 untuk melakukan serangan Pass-the-Hash).

Dalam laporan CTI, setiap kalimat ancaman HARUS diterjemahkan ke kode MITRE (T-Code). Jika sebuah buletin CTI berbunyi: *"Musuh membuang log Windows,"* analis CTI akan menerjemahkannya sebagai **T1070 (Indicator Removal)**. Ini memungkinkan komunikasi mesin antar SIEM (Elastic/Splunk) berjalan universal.

3.3 Profiling APT (Contoh: Lazarus Group)

Tugas CTI tingkat tinggi (Strategis/Operasional) adalah memahami perilaku **Advanced Persistent Threats (APTs)**—Grup peretas level negara (*State-Sponsored*) yang didanai pemerintah.

Setiap grup memiliki DNA khas (*Modus Operandi*). Sebagai contoh: **Lazarus Group (HIDDEN COBRA - Korea Utara)**.

- **Victimology (Target Korban):** Sangat berfokus pada spionase finansial. Mereka menargetkan Bank (Pencurian Jaringan SWIFT miliaran dolar) dan Bursa Kripto (*Cryptocurrency Exchanges*). Berbeda dengan Tiongkok yang biasanya mencuri kekayaan intelektual (Desain Senjata/Pabrik).
- **Infrastruktur/Kemampuan (TTPs):** Sering menggunakan kerentanan *Zero-Day* SMB, menyusupkan *malware* (WannaCry, BLINDINGCAN) untuk melumpuhkan jaringan dengan teknik penipuan *Wiper* (Menghapus *Disk* secara permanen untuk menutupi jejak pencurian uang).

Jika CTI internal (Sektor Perbankan di Asia Tenggara) mengetahui profil Lazarus ini, mereka akan memprioritaskan anggaran SOC mereka untuk membangun *Rule SIEM* pada deteksi gerbang SWIFT, daripada berfokus memantau pencurian desain dokumen pabrik.



BAGIAN IV

Threat Intelligence Platforms (TIP)
& Standarisasi Data (STIX/TAXII)

BAB 4: ARSITEKTUR PLATFORM CTI

4.1 Apa itu TIP? (Threat Intelligence Platform)

Membaca buletin PDF dari vendor keamanan (*CrowdStrike, Mandiant*) adalah langkah awal. Namun PDF tidak dapat dibaca (dan tidak dapat dieksekusi pemblokirannya) oleh mesin *Firewall*. Anda tidak mungkin mengetik ulang ribuan *Hash Malware* dari PDF ke dalam konsol *Firewall*.

Di sinilah peran **Threat Intelligence Platform (TIP)**. TIP adalah *server* repositori sentral (Otak Intelijen) milik perusahaan Anda yang bertugas:

1. **Agregasi (Pengumpulan):** Menyedot data *Feeds* dari puluhan sumber (OSINT, Vendor Berbayar, *Dark Web*) setiap 5 menit secara otomatis (melalui API).
2. **Korelasi & De-duplikasi:** Membersihkan data kembar. Jika 5 vendor melaporkan *Hash* yang sama, TIP menyatukannya menjadi 1 *Event* komprehensif.
3. **Integrasi Lintas-Mesin (Dissemination):** TIP terkoneksi ke SIEM (Elastic/Splunk) dan *Firewall* EDR. Begitu TIP menelan *IP* jahat baru, ia otomatis mendorong aturan *Block* (*Deny Rule*) ke *Firewall* tanpa klik dari manusia.

4.2 Arsitektur MISP (Malware Info Sharing Platform)

Standar industri (*Open Source*) yang digunakan oleh NATO, militer, dan CERT (*Computer Emergency Response Team*) nasional di seluruh dunia adalah **MISP**.

Sesuai namanya (*Sharing Platform*), MISP tidak berdiri sendiri. Ia berarsitektur federasi (*P2P/Federated*). *Server* MISP Bank BJB dapat disinkronkan secara aman (*Sync*) dengan *Server* MISP Bank Indonesia, dan *Server* MISP BSSN (Pemerintah).

> **Skenario Sinkronisasi MISP:**
> Jika Bank X terkena serangan *Phishing* baru hari ini, analis CTI Bank X akan mengunggah domain penyerang ke peladen MISP lokal mereka. Karena MISP mereka tersinkronisasi, peladen MISP Bank Y (mitra aliansi) akan menarik domain tersebut detik itu juga, dan otomatis memblokirnya di gerbang (*Gateway*) Bank Y, bahkan sebelum musuh sempat mengirim email ke Bank Y (*Herd Immunity*).

4.3 Standar Pertukaran Intelijen: STIX & TAXII

Agar seluruh TIP dan SIEM di dunia (yang berbeda merek) dapat saling bertukar data, diciptakanlah standar bahasa global bernama **STIX (Structured Threat Information Expression)** yang dikirim menggunakan protokol transportasi HTTP bernama **TAXII**.

STIX (Versi 2.1) adalah format JSON yang sangat kaku, merangkai hubungan antara Kampanye Ancaman, Alamat IP (*Observable*), dan Identitas APT.

```
# Contoh (Simplified) Format STIX 2.1 (Domain Malicious) { "type": "indicator", "id": "indicator-
-8e2e2d2b-17d4-4cbf-938f-98ee46b3cd3f", "created": "2026-05-14T08:17:27.000Z", "name": "File Hash C2
Emotet", "pattern": "[file:hashes.'SHA-256' =
'4bac27393bdd9777ce02453256c5577cd02275510b2227f473d03f533924f877']", "pattern_type": "stix",
"valid_from": "2026-05-14T08:17:27Z" }
```

Analis CTI yang andal wajib memahami *Python* (Pustaka `stix2`) untuk secara terprogram memanipulasi *Feed* STIX/TAXII dari vendor luar ke dalam SIEM Elastic internal.

4.4 Mengelola TLP (Traffic Light Protocol)

Berbagi intelijen (*Information Sharing*) mengandung risiko kebocoran rahasia perusahaan (Contoh: Berbagi sampel *malware* yang tidak sengaja mengandung nama dokumen *server* Anda). Forum CTI global (seperti FIRST) mengatur pembagian informasi menggunakan marka batas warna bernama **TLP (Traffic Light Protocol)**.

- **TLP:RED (Merah):** Rahasia Tertinggi. Informasi HANYA boleh diketahui oleh individu yang hadir/menerimanya secara langsung. Tidak boleh dibagikan ke departemen lain di kantor Anda (Bahkan Bos Anda).
- **TLP:AMBER (Kuning):** Distribusi Terbatas. Hanya boleh dibagikan di internal organisasi Anda, dan klien (*Customers*) yang secara langsung terdampak.
- **TLP:GREEN (Hijau):** Komunitas. Boleh dibagikan ke komunitas keamanan (Grup WhatsApp/Discord analis), namun DILARANG keras di-*posting* ke internet publik (Website/Twitter).
- **TLP:CLEAR (Putih/Clear):** Publik (OSINT). Bebas dibagikan ke seluruh dunia tanpa batas.

Setiap *Event* di platform MISP Anda secara wajib dikunci oleh label-label warna (*Tagging*) TLP ini secara *default*.



BAGIAN V

Operasionalisasi CTI di SOC
& Hypothesis-Driven Threat Hunting

BAB 5: CTI DALAM AKSI TAKTIS

5.1 Threat Hunting dengan Hipotesis

CTI bukanlah hiasan (*Dashboard*). CTI adalah pemicu (*Trigger*) untuk **Threat Hunting (Perburuan Ancaman)**. *Threat Hunting* bukanlah mengetik kata kunci acak di SIEM; ia berpedoman pada metode saintifik yang digerakkan oleh **Hipotesis** intelijen.

Langkah Perburuan (The Hunt Loop):

1. **Hipotesis (Bersumber dari CTI):** *Laporan C-ISA menyebutkan APT29 aktif menyerang via email Phishing yang menjatuhkan (Dropper) fail IMG.* Hipotesis: "Ada kemungkinan musuh sudah masuk (mengirim fail `.img`) ke *Inbox* Eksekutif Perusahaan selama 30 hari terakhir."
2. **Investigasi:** Analis menulis kueri SIEM/EDR, mencari segala aktivitas ekstensi `.img` yang diunduh dari klien *Outlook/Webmail*.
3. **Penemuan (Discovery):** (Entah ditemukan ancaman, atau nihil/Aman).
4. **Otomatisasi Baru:** Analis membuat *Rule* peringatan statis KQL baru (*Detection Engineering*) agar tidak perlu memburu hal ini secara manual di masa depan.

5.2 Penulisan Aturan YARA dari Laporan CTI

Dalam investigasi forensik dan berburu berkas (*Files*), *Threat Hunters* menggunakan mesin penanda (*Pattern-Matching Engine*) universal yang disebut **YARA** (*Yet Another Ridiculous Acronym*). YARA bagaikan *Regex* (Ekspresi Reguler) khusus untuk *Malware*.

Jika intelijen menyatakan bahwa ada *Ransomware* jenis baru yang menggunakan teknik *String Obfuscation* unik dan selalu memuat pustaka (*Library*) kompresi `zlib.dll`, analis CTI akan menulis aturan (*Rule*) YARA untuk disebarkan ke sensor EDR perusahaan:

```
// OSINT / CTI YARA Rule: Deteksi Ransomware Varian XYZ rule APT_Ransomware_XYZ_Behavior { meta: author = "SOC CTI Analyst" description = "Mendeteksi struktur string unik milik Geng XYZ" mitre_tactic = "T1486 (Data Encrypted for Impact)" tlp = "AMBER" strings: // Hexadesimal header dari file (Magic Bytes = MZ / Executable) $mz = { 4D 5A } // String hardcoded khas milik penyerang yang terbaca di Memory $str1 = "YOUR_FILES_ARE_LOCKED_XYZ" ascii wide nocase $str2 = "zlib.dll" ascii condition: // Logika: Harus file .exe (MZ) DAN mengandung string 1 dan string 2. ($mz at 0) and ($str1 and $str2) }
```

5.3 Integrasi CTI dengan SOAR (Auto-Blocking)

Platform intelijen ancaman tidak boleh menjadi *Silo* (terisolasi). Platform tersebut harus mendorong datanya (*Indicators*) secara proaktif. Mesin orkestrasi **SOAR (Security Orchestration, Automation, and Response)** adalah lemnya.

Setiap pagi, SOAR menjalankan skrip Python (*Cron Job*) yang menarik daftar 500 domain jahat terbaru (*Fresh Domains - TLP:CLEAR*) dari repositori CTI/MISP Anda.

Alih-alih menyuruh manusia menekan tombol blokir, SOAR menggunakan **API Panggilan (RESTful)** ke *Gateway Firewall* tepi jaringan Anda (Contoh: Palo Alto atau Cloudflare) dan memperbarui daftar Blokir Dinamis (*External Dynamic List/EDL*).

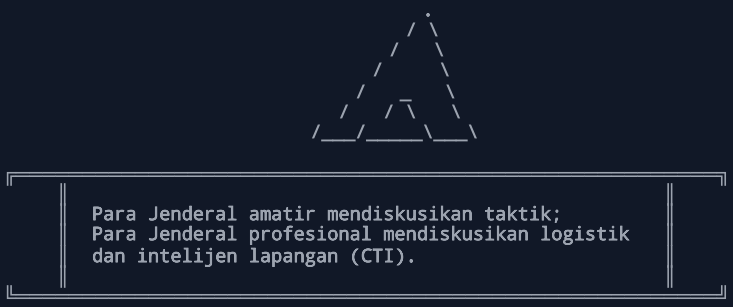
Dengan ekosistem CTI ini, jika sebuah Geng Peretas *Botnet* di Eropa mendaftarkan domain baru pada jam 13:00, platform CTI publik akan melaporkannya pada jam 13:05, MISP Anda akan menariknya pada jam 13:10, dan *Firewall* perusahaan Anda akan memblokir domain tersebut secara absolut pada jam 13:15. Ini adalah sistem kekebalan (*Immune System*) level *Enterprise* yang sejati.

GLOSARIUM CTI & OSINT (A-M)

TERMINOLOGI	DEFINISI & KONSEP OPERASIONAL
APT (Advanced Persistent Threat)	Grup musuh dengan sumber daya masif (biasanya didanai negara/militer) yang meretas diam-diam dan tinggal berminggu-minggu dalam jaringan korban untuk pencurian spionase.
Diamond Model	Kerangka analitik untuk membedah sebuah insiden intrusi ke dalam empat poros: *Adversary, Capability, Infrastructure, Victim*.
IoA vs IoC	*IoC (Indicator of Compromise)*: Bukti (seperti Hash/IP) bahwa Anda sudah diretas. *IoA (Indicator of Attack)*: Bukti perilaku/niat penyerang saat serangan sedang berlangsung.
MISP	*Malware Information Sharing Platform*. Perangkat lunak komunitas sumber terbuka untuk membangun, menyimpan, dan berbagi repositori Indikator Ancaman (IoC).
MITRE ATT&CK	Matriks standar global (kamus taktik & teknik) yang menjelaskan **Bagaimana** dan **Mengapa** musuh melakukan langkah peretasan mereka.

GLOSARIUM CTI & OSINT (N-Z)

TERMINOLOGI	DEFINISI & KONSEP OPERASIONAL
OSINT	*Open-Source Intelligence*. Metode investigasi (Pengintaian) pasif melalui peramban, *Search Engine*, catatan publik, dan *Dark Web* tanpa pernah menyentuh langsung target.
Pyramid of Pain	Model konseptual yang mengurutkan Indikator Ancaman berdasarkan tingkat kesulitan yang akan diderita oleh peretas (Musuh) jika Anda berhasil memblokirnya (TTPs di puncak).
STIX/TAXII	Protokol dan format struktur data JSON global (Bahasa Mesin) yang memungkinkan Sistem A (MISP) dan Sistem B (Elastic SIEM) bertukar *Threat Feeds* secara otomatis.
TLP	*Traffic Light Protocol*. Label warna (Red, Amber, Green, Clear) untuk menentukan tingkat kerahasiaan saat berbagi buletin informasi intelijen antar perusahaan.
YARA	Bahasa penanda pola (*Pattern-Matching Engine*) tingkat lanjut yang digunakan analis/CTI untuk mendeteksi struktur teks/*hex Malware* di memori RAM maupun disk (*File System*).



The Tactical Mind

© 2026 All rights reserved.
Threat Intelligence & Reconnaissance